

##CRISCd - Information Technology and Security Principles

###Objectives:

At the end of this episode, I will be able to understand:

1. Practitioners should understand that privacy is similar to confidentiality
2. Difference between privacy and confidentiality: Rights regarding the handling and retention of a subject's PII (Personal Identifiable Information)
3. These rights are still valid even if the data is not in the subject's control
4. Data privacy concepts to know for exam:
 - INFORMED CONSENT – Data subject to privacy regulations should be collected, used and retained with the informed consent. A signed consent form is typically attached.
 - PIA – These identify and manage risk related to privacy whenever personal information is collected. PIAs typically cover how information is used, shared and maintained. Similar to a risk assessment.
 - MINIMIZATION – Risk practitioners should understand that the MORE data that you keep around...the more of a risk surface area you have.
 - DESTRUCTION – Data should generally be destroyed once its reason to exist is over. However, some data must be retained for a certain time due to legal and regulatory reasons.

Additional resources used during the episode can be obtained using the download link on the overview episode.

External Resources:

During this episode, you can reference the following external resources for supplementary tools and information:

<http://www.isaca.org>